

Lab 2 – Setuid

Sicurezza dei Sistemi e delle reti

Modulo 3 - Autenticazione e controllo degli accessi

Unità didattica 3 – Controllo degli accessi nei sistemi operativi

Stelvio Cimato

Università degli Studi di Milano - SSRI - CdL Online

Necessità di programmi privilegiati

- Autorizzazioni del file / etc /shadow:

```
-rw-r----- 1 root shadow 1443 May 23 12:33 /etc/shadow
```

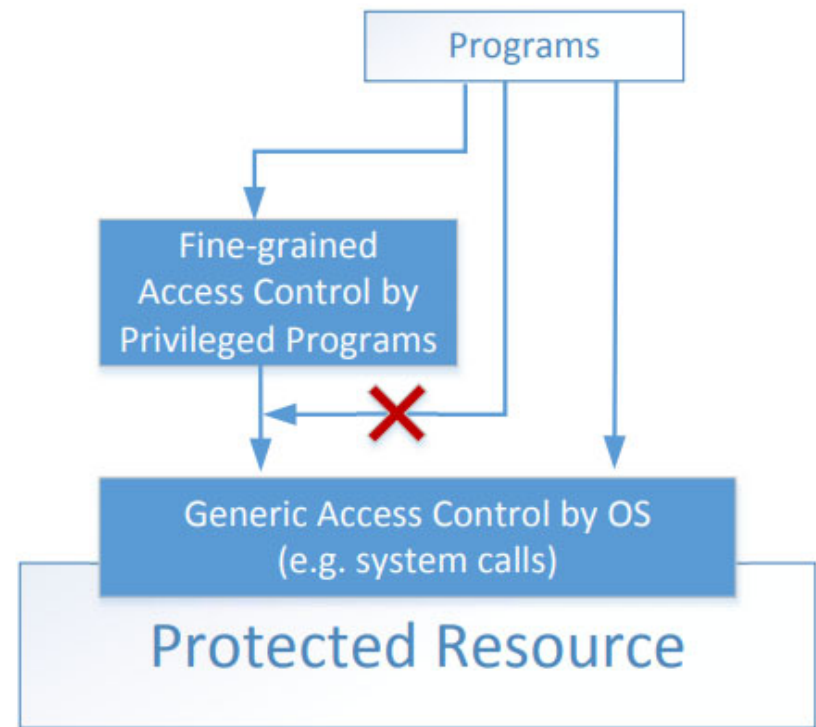
↑ Only writable to the owner

- In che modo gli utenti normali cambierebbero la propria password?

```
root:$6$012BPz.K$fbPkT6H6Db4/B8cLWbQI1cFjn0R25yqtqrSrFeWfCgybQWWnwR4ks/.rjqyM7Xw  
h/pDyc5U1BW0zkWh7T9ZGu.:15933:0:99999:7:::  
daemon*:15749:0:99999:7:::  
bin*:15749:0:99999:7:::  
sys*:15749:0:99999:7:::  
sync*:15749:0:99999:7:::  
games*:15749:0:99999:7:::  
man*:15749:0:99999:7:::  
lp*:15749:0:99999:7:::
```

Approccio a due livelli

- **L'implementazione di un controllo degli accessi capillare nei sistemi operativi rende il sistema operativo estremamente complicato.**
- **Il sistema operativo si basa sull'estensione per applicare un controllo capillare degli accessi**
- **I programmi privilegiati sono tali estensioni**



Tipi di programmi privilegiati

- **Demoni**

- Programma per computer che viene eseguito in background
- Deve essere eseguito come root o altri utenti privilegiati

- **Programmi Set-UID**

- Ampiamente utilizzato nei sistemi UNIX
- Programma contrassegnato con un bit speciale

Concetto di set-UID

- **Consenti all'utente di eseguire un programma con i privilegi del proprietario del programma.**
- **Consentire agli utenti di eseguire programmi con privilegi elevati temporanei**
- **Esempio: il programma passwd**

```
$ ls -l /usr/bin/passwd
```

```
- rw s r-xr-x 1 root root 41284 12 settembre 2012  
/usr/bin/passwd
```

Concetto di set-UID

- **Ogni processo ha due ID utente .**
- **UID reale (RUID) : identifica il vero proprietario del processo**
- **UID effettivo (EUID) : identifica i privilegi di un processo**
 - Il controllo degli accessi si basa sull'EUID
- **Quando viene eseguito un programma normale, $RUID = EUID$, entrambi equivalgono all'ID dell'utente che esegue il programma**
- **Quando viene eseguito un Set-UID, $RUID \neq EUID$. RUID è ancora uguale all'ID dell'utente, ma EUID è uguale all'ID del proprietario del programma .**
 - Se il programma è di proprietà di root, il programma viene eseguito con i privilegi di root.

Trasforma un programma in Set-UID

- **Cambia il proprietario di un file in root:**

```
seed@VM:~$ cp /bin/cat ./mycat
seed@VM:~$ sudo chown root mycat
seed@VM:~$ ls -l mycat
-rwxr-xr-x 1 root seed 46764 Nov  1 13:09 mycat
seed@VM:~$
```

- **Prima di abilitare il bit Set-UID:**

```
seed@VM:~$ mycat /etc/shadow
mycat: /etc/shadow: Permission denied
seed@VM:~$
```

- **Dopo aver abilitato il bit Set-UID:**

```
seed@VM:~$ sudo chmod 4755 mycat
seed@VM:~$ mycat /etc/shadow
root:$6$012BPz.K$fbPkT6H6Db4/B8cLWbQI1cFjn
h/pDyc5U1BW0zkWh7T9ZGu.:15933:0:99999:7:::
daemon:*:15749:0:99999:7:::
bin:*:15749:0:99999:7:::
sys:*:15749:0:99999:7:::
```

Come funziona

- **Un programma Set-UID è proprio come qualsiasi altro programma, tranne per il fatto che ha un contrassegno speciale, che un singolo bit chiamato bit Set-UID**

```
$ cp /bin/id ./myid
$ sudo chown root myid
$ ./myid
uid=1000(seed) gid=1000(seed) groups=1000(seed), ...
```

```
$ sudo chmod 4755 myid
$ ./myid
uid=1000(seed) gid=1000(seed) euid=0(root) ...
```


Esempio di impostazione dell'UID

```
$ cp /bin/cat ./mycat
$ sudo chown root mycat
$ ls -l mycat
-rwxr-xr-x 1 root seed 46764 Feb 22 10:04 mycat
$ ./mycat /etc/shadow
./mycat: /etc/shadow: Permission denied
```

```
$ sudo chmod 4755 mycat
$ ./mycat /etc/shadow
root:$6$012BPz.K$fbPkT6H6Db4/B8c...
daemon:*:15749:0:99999:7:::
...
```

```
$ sudo chown seed mycat
$ chmod 4755 mycat
$ ./mycat /etc/shadow
./mycat: /etc/shadow: Permission denied
```

- ← Non è un programma privilegiato
- ← Diventa un programma privilegiato
- ← È ancora un programma privilegiato, ma non il privilegio di root

In che modo Set-UID è sicuro?

- **Consente agli utenti normali di aumentare i privilegi**
 - Diverso dal dare direttamente il privilegio (comando sudo)
 - Comportamento limitato
- **Non è sicuro trasformare tutti i programmi in Set-UID**
 - Esempio: /bin/ sh
 - Esempio: vi

Superficie di attacco dei programmi Set-UID

